



TEMA 128. LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO. PLANES DE CONTINUIDAD Y CONTINGENCIA DEL NEGOCIO

Actualizado a 10/01/2022

1. LA GESTIÓN DE LA CONTINUIDAD DEL NEGOCIO

La gestión de la continuidad del negocio **ayuda a disminuir la posibilidad de ocurrencia de un incidente**, y en caso de producirse este ofrece a la empresa los medios para responder, reducir el daño causado y recuperarse lo antes posible.

1.1. NORMA ISO 22301

- Define los requisitos para implementar, mantener y mejorar un sistema de gestión de la continuidad del negocio (SGCN) para proteger y reducir la probabilidad de ocurrencia, prepararse, responder y recuperarse de interrupciones cuando éstas surjan. Todo ello en línea con el enfoque de mejora continua Plan-Do-Check-Act.
- Establece la información que debe incorporarse al SGCN, entre la que se encuentra:
 - El contexto de la organización (alcance, partes interesadas, requisitos legales, reglamentarios, normativos...)
 - Política de la continuidad de negocio.
 - Objetivos de la continuidad del negocio.
 - Análisis del impacto en el negocio (BIA).
 - Evaluación de los riesgos.
 - Estrategias y soluciones de continuidad del negocio para antes, durante y después de la interrupción (planes de continuidad, procedimientos de recuperación ...)
 - Programas de pruebas
 - Evaluación del desempeño (seguimiento, auditoría interna, revisión por la dirección)
 - Mejora continua (oportunidades de mejora, no conformidades y acciones correctiva.
- Son aspectos fundamentales la elaboración de **un plan de contingencias, la determinación del alcance y del nivel de riesgo** aceptado por parte de la dirección y alineada con la estrategia.

1.2. ENS: PLAN DE CONTINUIDAD DE NEGOCIO

- Art. 25 RD 3/2010, Continuidad de la actividad: “*Los sistemas dispondrán de copias de seguridad y establecerán los mecanismos necesarios para garantizar la continuidad de las operaciones, en caso de pérdida de los medios habituales de trabajo*”.
- Es una medida operativa, solo aplica a la **dimensión de Disponibilidad de nivel alto**.
- Para proteger la operación del sistema, en caso de interrupción de los servicios prestados con los medios habituales, como conjunto integral de componentes para un fin.

1.3. ISO 27001 SISTEMA DE GESTIÓN DE LA SEGURIDAD DE LA INFORMACIÓN

- Especifica los requisitos para el establecimiento, implementación, mantenimiento y mejora continua de un sistema de gestión de la seguridad de la información que preserve la confidencialidad, integridad y disponibilidad de dicha información.
- Como parte fundamental para asegurar la disponibilidad de la información, la norma incluye en su anexo, objetivos y controles relacionados con la continuidad de negocio.

2. PLAN DE CONTINUIDAD Y CONTINGENCIA DE NEGOCIO

Incluyen los mecanismos, en caso de un incidente grave de seguridad, interrupción o fallo de los procesos críticos, para dar una respuesta rápida y eficaz, de proteger al personal y los activos, de manera que podamos recuperar la actividad normal en un plazo de tiempo tal sin que se comprometa el negocio.

Según INCIBE, tipos de planes:

- **Plan de Continuidad de Negocio (PCN o BCP en inglés)** que establece la continuidad de una organización desde múltiples perspectivas (infraestructura TIC, RR. HH, logística, etc.).
- **Plan de Continuidad TIC (Plan de Contingencia TIC, PCTIC)**, de ámbito TIC. Compuesto de:
 - **Plan de Respaldo:** contempla las medidas preventivas ANTES
 - **Plan de Emergencia:** contempla las medidas paliativas o minimizadoras DURANTE
 - **Plan de Recuperación:** contempla las medidas necesarias DESPUÉS
- **Plan de Recuperación ante Desastres (PRD).** En este caso, su fase de análisis es menos profunda y se enfoca al ámbito más técnico, de modo que es un plan reactivo ante una posible catástrofe.

2.1. FASES DEL PCN (SEGÚN INCIBE)

FASE 0: DETERMINACIÓN DEL ALCANCE

- Según el coste y viabilidad, se determinarán los elementos que van a ser el foco del PCN
- Enfoques:
 - por activo: más apropiado cuando el proyecto lo dirige el equipo Informático.
 - por proceso: más apropiado cuando el proyecto es liderado por el Negocio.

FASE 1: ANÁLISIS DE LA ORGANIZACIÓN

- Realización de **entrevistas**
- Elaboración un **Análisis de impacto sobre el Negocio o BIA**, determinando: RPO, RTO, MTD, ROL
- Elaboración de un **análisis de riesgos** determinando amenazas, probabilidad, impacto y riesgo.
- Determinación de un **plan de tratamiento de riesgos** que incluya las medidas para tratarlos, la fecha límite de implantación, el responsable de este y los recursos necesarios.

FASE 2: DETERMINACIÓN DE LA ESTRATEGIA DE CONTINUIDAD.

- Determinar si los recursos y estrategias actuales y sus estrategias cubren el MTD establecido.
- Definición del **conjunto de roles y responsabilidades del equipo** de crisis. (multidisciplinar).
- Determinación el **plan de comunicación** (fijando un único interlocutor).
- Valoración del **coste y viabilidad de su implantación y mantenimiento**.

FASE 3: RESPUESTA A LA CONTINGENCIA.

- Implementación de las iniciativas y elaboración de documentación, incluido:
 - El **Plan de Crisis o de incidentes**.
 - Los **planes operativos de recuperación de entornos**.
 - Los **procedimientos técnicos de trabajo**.

FASE 4: PRUEBA, MANTENIMIENTO Y REVISIÓN.



- Según **planificación previa** y siempre al menos una vez al año. Adicionalmente:
 - **Plan de mantenimiento** (actualizado y documentado).
 - **Plan de pruebas** (actualizado y documentado).

FASE 5. PLAN DE CONCIENCIACIÓN.

- Para todo el personal, en especial el responsable, técnico y participantes en el equipo de crisis.